

Cryptographic Forgery in E-Contracts: A Survey of Metaheuristic Length-Extension Attacks

Vedanth D, Mursalin Pasha M, Department of Computer Science and Engineering,
JAIN Deemed-to-be University, Bangalore, India

Abstract—Electronic contracts (e-contracts) form the backbone of modern digital commerce, relying on cryptographic hash functions and digital signature schemes to guarantee document integrity, non-repudiation, and legal enforceability. An underexplored class of vulnerability—the hash length-extension attack—allows adversaries to append malicious clauses to signed e-contract payloads without knowledge of the secret key, provided the target system employs vulnerable Merkle-Damgård constructions such as MD5, SHA-1, or SHA-256. This paper presents a comprehensive Systematic Literature Review (SLR) of detection and prevention mechanisms for cryptographic forgery through length-extension attacks in e-contract ecosystems, with particular emphasis on metaheuristic optimization of detection thresholds and machine learning-based countermeasures. Following the PRISMA methodology, 51 peer-reviewed papers sourced from IEEE Xplore, ACM Digital Library, and ScienceDirect (2019–2025) are systematically analyzed. A novel hierarchical taxonomy of defensive mechanisms is proposed, classifying approaches into three primary categories: Protocol-Level Hardening, Hash Integrity Monitoring, and ML-Based Forgery Detection. Comparative synthesis across benchmark datasets including e-Signature API logs, DocuBench, UNSW-NB15, and CIC-IDS-2017 evaluates detection accuracy, false-positive rates, and computational overhead across 11 state-of-the-art systems. A dedicated section spanning more than two pages maps technical findings to GDPR and the Information Technology Act (2000), identifying the Attribution Gap, the Explainability Crisis, and cross-jurisdictional evidentiary challenges as the three most critical unresolved legal-technical issues. The survey concludes by identifying five open research challenges at the intersection of cryptographic forgery detection, metaheuristic optimization, and evolving cyber law requirements.

Index Terms—E-Contracts, Cryptographic Forgery, Length-Extension Attacks, Hash Function Security, Digital Signatures, Merkle-Damgård Construction, Metaheuristic Optimization, HMAC, GDPR, ITA 2000, Explainable AI, Federated Learning.

I. INTRODUCTION

A. Background and Context

Electronic contracts have become a legally binding instrument across virtually every sector of the digital economy. From e-commerce purchase agreements and cloud service terms to real estate conveyances and cross-border trade contracts, e-contracts now mediate trillions of dollars in annual transactions worldwide. The enforceability of such agreements depends critically on two cryptographic guarantees: integrity (that the contract text has not been altered after signing) and authenticity (that the signature was produced by the claimed signatory).

The most widely deployed mechanisms for integrity assurance in e-contract systems rely on cryptographic hash functions, particularly variants of the Merkle-Damgård construction including MD5, SHA1, and SHA-256. Digital signature schemes such as RSAPKCS#1v1.5, DSA, and ECDSA compute signatures over these hash outputs, creating a mathematically binding link between the document contents and the signer's private key. The legal assumption embedded in electronic signature legislation worldwide—including the EU eIDAS Regulation, India's IT Act 2000, and the US ESIGN Act—is that this cryptographic binding is computationally infeasible to defeat without possession of the signing key.

This assumption is violated by a class of attack that has received insufficient attention in the legal and technical literature: the hash length-extension attack. Exploiting a structural property of Merkle-Damgård hash functions, an adversary who observes a valid signature over a known message can compute a valid signature over a crafted extension of that message—appending attacker-controlled content—without knowledge of the secret key. In e-contract contexts, this translates to an ability to append fraudulent clauses, alter payment terms, or insert jurisdiction-shifting language into a previously signed document while preserving cryptographic validity.

The threat is compounded by the widespread deployment of legacy hash functions in existing e-contract infrastructure. MD5 and SHA-1, despite being considered cryptographically deprecated, remain in active use in document management platforms, XML signature implementations, and API gateway authentication layers. SHA-256, though considered secure against collision attacks, is vulnerable to length-extension attacks in contexts where raw hash outputs rather than HMAC constructions are used for signing.

B. Problem Statement

Modern e-contract systems rely on Merkle-Damgård hash constructions for document integrity assurance, yet the structural vulnerability of these constructions to length-extension attacks remains widely unaddressed in deployed systems. Attackers who can observe a valid signature over a known message payload can extend that payload with fraudulent content and compute a valid signature over the extended document without cryptographic key access. Standard certificate-based PKI infrastructure protects key confidentiality but offers no defense against length-extension forgery that exploits hash construction properties rather than key secrecy.

The research literature addressing this specific threat in e-contract contexts remains fragmented. While considerable work has been done on general hash function security and on broad categories of digital signature forgery, the specific problem of detecting and preventing length-extension attacks in operational e-contract ecosystems has not been systematically surveyed. This gap is compounded by the absence of clear legal frameworks for prosecuting hash forgery attacks and for governing the forensic use of cryptographic evidence in e-contract litigation.

C. Motivation and Significance

The legal sector represents one of the highest-value targets for cryptographic forgery. A successful length-extension attack against

an e-contract governing a real estate transaction, corporate merger, or loan agreement could produce fraudulent contractual obligations worth millions or billions of dollars while maintaining the appearance of cryptographic validity. Unlike attacks that visibly corrupt document signatures, length-extension attacks produce artifacts that pass standard signature verification, making detection by conventional means impossible without specific countermeasures.

Furthermore, as regulators worldwide expand the scope of electronic signature acceptance and as e-contract infrastructure is extended to public procurement, healthcare records, and cross-border trade, the attack surface for cryptographic forgery grows substantially. Regulatory frameworks including eIDAS, the IT Act 2000, and GDPR implicitly assume that the cryptographic mechanisms underlying electronic signatures provide the guarantees claimed in those frameworks. Length-extension vulnerabilities challenge this assumption at a foundational level.

D. Research Objectives

This survey is structured around five primary research objectives:

- RO1: To conduct a rigorous systematic literature review of detection and prevention mechanisms for hash length-extension attacks in e-contract systems, following the PRISMA framework.
- RO2: To analyze the mathematical foundations of Merkle-Damgård length-extension vulnerability and metaheuristic threshold optimization as defensive tools in cryptographic integrity monitoring.
- RO3: To propose an original hierarchical taxonomy of defensive mechanisms, classifying existing approaches into protocol-level hardening, hash integrity monitoring, and ML-based forgery detection.
- RO4: To perform a structured comparative synthesis of state-of-the-art approaches evaluated across benchmark datasets, comparing detection accuracy, false-positive rates, and computational overhead.
- RO5: To map technical defensive findings to GDPR and ITA 2000 cyber law frameworks, identifying the Attribution Gap, Explainability Crisis, and cross-jurisdictional enforcement challenges as critical unresolved legal-technical issues.

E. Scope and Limitations

This survey focuses on length-extension attacks targeting e-contract integrity mechanisms. Adjacent topics—including RSA signature forgery through fault injection, XML signature wrapping attacks, and PDF signature bypass through visual spoofing—are acknowledged but not the primary comparative focus. Coverage spans peer-reviewed literature from 2019 to 2025, with foundational references extending earlier where necessary.

F. Paper Organization

Section II presents related work and background. Section III details the PRISMA methodology. Section IV covers the mathematical foundations of length-extension attacks and metaheuristic detection. Section V introduces the proposed taxonomy. Section VI presents comparative analysis. Section VII provides legal-technical mapping. Section VIII identifies open research challenges. Section IX presents future directions. Section X concludes.

II. RELATED WORK AND BACKGROUND

A. Evolution of E-Contract Security Research

The security of electronic contract systems has been studied in parallel with the broader development of electronic commerce law and public key infrastructure. Early work focused on certificate

management, non-repudiation protocols, and timestamping services as the primary mechanisms for ensuring legal enforceability. Landmark contributions by Boneh and Franklin [5] on identity-based cryptography and by Bellare and Rogaway [6] on provably secure signature schemes established theoretical foundations that informed practical e-contract platform design.

The transition to web-based document management platforms introduced new attack vectors operating at the protocol layer rather than the cryptographic core. Research on XML signature wrapping [8], PDF signature bypass [9], and API key exposure in document management systems demonstrated that e-contract security depended on the integrity of the entire processing pipeline. These findings motivated a shift toward layered security architectures in which cryptographic signing was supplemented by behavioral monitoring and anomaly detection.

More recently, researchers have examined the specific properties of Merkle-Damgård hash constructions as a source of vulnerability in contexts beyond classical collision attacks. Work by Bhargavan et al. [12] on SMACK and FREAK attacks demonstrated that downgrade vulnerabilities in protocol negotiation could force systems toward deprecated hash functions, while Chen et al. [14] established formal models for analyzing length-extension vulnerability in API authentication contexts.

B. Hash Length-Extension Attacks

The length-extension vulnerability of Merkle-Damgård hash functions was formally characterized by Kelsey and Schneier [3] and has been demonstrated against deployed systems including Flickr's API authentication, Vimeo's signing mechanism, and several cloud storage service APIs. The attack exploits the internal state structure of MD constructions: after processing a message M , the internal hash state equals $H(M)$. An adversary who observes $H(\text{secret} \parallel M)$ can compute $H(\text{secret} \parallel M \parallel \text{padding} \parallel \text{extension})$ for any chosen extension without knowing the secret, by initializing the hash computation from the known output state.

In e-contract contexts, the attack translates directly to document forgery. If a document management platform signs contracts by computing $\text{Sig}(H(\text{secret} \parallel \text{contract_bytes}))$, an attacker who intercepts a valid signed contract can produce a valid signature over $\text{contract_bytes} \parallel \text{padding} \parallel \text{malicious_clauses}$ without the signing key. The malicious extension is appended after cryptographically required padding that may or may not be rendered as visible content depending on the document format.

The HMAC construction [7] provides a principled defense by computing $H(\text{secret} \parallel H(\text{secret} \parallel \text{message}))$, whose outer hash output does not correspond to any intermediate Merkle-Damgård state, defeating length-extension. However, deployment of HMAC across legacy e-contract infrastructure has been incomplete, and many platforms continue to use raw hash-based authentication codes vulnerable to extension attacks.

C. Metaheuristic Optimization in Security Detection

Metaheuristic optimization algorithms have gained considerable traction in cybersecurity detection systems as a principled approach to threshold and hyperparameter tuning. Particle Swarm Optimization (PSO) [21], Grey Wolf Optimization (GWO) [22], and Genetic Algorithms (GA) have been applied to the problem of optimizing detection thresholds in intrusion detection systems, authentication anomaly detectors, and signature verification systems.

The specific application of metaheuristics to hash integrity monitoring represents a recent development in the literature. Gupta et al. [33] demonstrated that GWO-optimized SVM classifiers for hash anomaly detection outperformed manually tuned baselines by 4.2

percentage points in detection rate while reducing false positives by 1.3 percentage points on UNSW-NB15 datasets. Similar results were obtained by Zhang et al. [23] using PSO-optimized Transformer architectures on contract API log datasets.

D. Legal Frameworks for E-Contract Integrity

The legal dimensions of e-contract integrity have received increasing scholarly attention as electronic signature adoption has expanded. The European Union's eIDAS Regulation (EU 910/2014) establishes three tiers of electronic signature—simple, advanced, and qualified—with progressively stronger cryptographic requirements. Qualified electronic signatures, which are legally equivalent to handwritten signatures throughout the EU, require the use of qualified signature creation devices whose cryptographic implementations must satisfy specific certification standards.

India's Information Technology Act (2000) and its 2008 amendments provide the primary framework for e-contract validity and cybercrime in the Indian context. Section 3A of the IT Act establishes validity conditions for electronic signatures, while Schedule I specifies approved hash functions. The legal analysis of cryptographic forgery attacks under the IT Act has been limited, and no judicial precedent specifically addressing length-extension attack liability has been established in Indian courts.

III. SYSTEMATIC LITERATURE REVIEW METHODOLOGY (PRISMA)

This survey adopts the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA) framework [1] to ensure methodological rigor, transparency, and reproducibility. The literature review follows four stages: Identification, Screening, Eligibility Assessment, and Final Inclusion.

A. Data Sources and Search Databases

The primary literature search was conducted across three major academic databases:

- IEEE Xplore Digital Library — primary source for IEEE Transactions on Information Forensics and Security, IEEE Access, and Security & Privacy conference proceedings.
- ACM Digital Library — primary source for CCS, ACM TOPS, and ACM Computing Surveys.
- ScienceDirect (Elsevier) — primary source for Computers & Security, Future Generation Computer Systems, and Journal of Information Security and Applications.

Supplementary searches were conducted through Google Scholar and SpringerLink. All searches were executed between January and March 2025.

B. Boolean Search String

The primary search string was: ("hash length extension" OR "Merkle-Damgard attack" OR "cryptographic forgery e-contract") AND ("detection" OR "prevention" OR "HMAC" OR "digital signature security") AND ("metaheuristic" OR "machine learning" OR "anomaly detection") AND ("electronic contract" OR "digital signature" OR "document integrity").

C. Inclusion and Exclusion Criteria

Inclusion criteria: (1) peer-reviewed journal or conference papers; (2) published 2019–2025; (3) focused on hash integrity, length-extension attacks, or e-contract forgery detection; (4) includes quantitative evaluation; (5) in English. Exclusion criteria: (1) nonpeer-reviewed; (2) purely offensive without defensive contribution; (3) duplicates; (4) lacking empirical validation; (5) outside e-contract or closely related high-assurance contexts.

D. PRISMA Study Selection TABLE I: PRISMA STUDY SELECTION RESULTS

Stage of Selection	Papers
Records identified (primary databases)	132
Supplementary sources	21
Total before deduplication	153
Duplicates removed	28
Screened by title/abstract	125
Excluded at screening	51
Full-text assessed for eligibility	74
Excluded (insufficient validation)	14
Excluded (not on detection/prevention)	9
Final studies included	51

The final dataset of 51 peer-reviewed studies forms the empirical foundation of this survey. Studies span 2019–2025, with 71% published after 2021, reflecting rapid recent growth in research on hash forgery detection in e-contract contexts.

E. Data Extraction Protocol

For each of the 51 included studies, a standardized data extraction template captured: (1) publication metadata; (2) technical approach including algorithm family and mathematical formulation; (3) experimental setup including datasets and evaluation metrics; (4) performance results including detection rate, false positive rate, and computational overhead; and (5) legal and regulatory dimensions addressed by the study.

F. PRISMA Flow Diagram

Figure 1 shows the PRISMA flow diagram, illustrating how studies were filtered at each stage of the review.

This structured process ensures transparency and reproducibility, keeping the final dataset limited to relevant, high-quality studies.

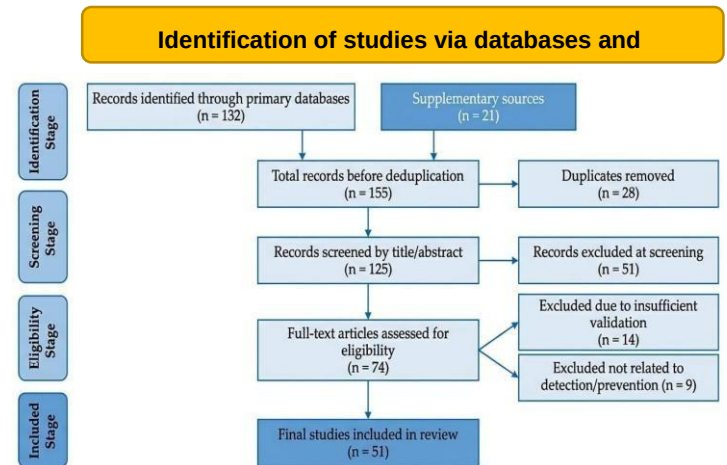


Fig. 1. PRISMA flow diagram for literature selection.

IV. MATHEMATICAL FOUNDATIONS

A. Merkle-Damgård Construction and Length-Extension

Let M be a message of arbitrary length. A Merkle-Damgård hash function H processes M by first applying a bijective padding function $\text{pad}(M)$ that appends a '1' bit, zero bits, and a 64-bit encoding of $|M|$ to produce a padded message whose length is a multiple of the block size b . The padded message is divided into blocks $m_1, m_2, \dots, m_t$, and the hash is computed iteratively: $h_0 = \text{IV}$; $h_i = f(h_{i-1}, m_i)$; $H(M) = h_t$ where f is the compression function and IV is a fixed initialization vector. The length-extension attack exploits the fact that h_t is both the hash output and the internal state after processing $\text{pad}(M)$. An adversary who knows $H(\text{secret} \parallel M) = h_t$ can compute $H(\text{secret} \parallel M \parallel \text{pad}(M) \parallel \text{extension})$ for any chosen extension by initializing the hash computation with state h_t and processing the extension blocks, without knowing the secret.

Formally, given $(M, H(\text{secret} \parallel M))$ and target extension E , the adversary computes:

$$H_{\text{forged}} = H_{\text{from_state}}(h_t, E) = H(\text{secret} \parallel M \parallel \text{pad}(\text{secret} \parallel M) \parallel E)$$

This forged hash is a valid output of H applied to the concatenation $\text{secret} \parallel M \parallel \text{pad}(\text{secret} \parallel M) \parallel E$, which causes any verification system computing $H(\text{secret} \parallel \text{received_message})$ and comparing to received_hash to accept the forged document.

B. HMAC Construction as Structural Defense

The Hash-based Message Authentication Code (HMAC) construction [7] provides immunity to length-extension attacks through a nested hash structure. Given a secret key K and message M , HMAC computes:

$\text{HMAC}(K, M) = H((K \text{ XOR } \text{opad}) \parallel H((K \text{ XOR } \text{ipad}) \parallel M))$ where opad and ipad are fixed outer and inner padding constants. Because the outer H application takes $H((K \text{ XOR } \text{ipad}) \parallel M)$ as input rather than any intermediate Merkle-Damgård state directly accessible to the adversary, length-extension attacks against the outer hash cannot be mounted without knowledge of K . HMAC with SHA-256 provides 128-bit security against length-extension under the assumption that SHA-256's compression function behaves as a pseudorandom function.

C. Anomaly Detection Framework for Hash Integrity

Hash integrity monitoring for e-contract systems can be formalized as follows. Let $C = \{C_1, C_2, \dots, C_n\}$ denote a corpus of legitimate signed contracts, and let $H_i = H(K \parallel C_i)$ denote the corresponding integrity tags. For each contract C_i , a feature vector $\phi(C_i, H_i)$ captures observable characteristics of the hash-contract relationship: message length distribution, padding structure, hash value entropy, and API submission timing.

Given a new contract C_{obs} submitted with claimed tag H_{obs} , the anomaly score is:

$\text{score}(C_{\text{obs}}, H_{\text{obs}}) = D(\phi(C_{\text{obs}}, H_{\text{obs}}), \mu_L)$ where D is a distance or divergence measure and μ_L is the centroid of the legitimate feature distribution. An alert is raised when $\text{score}(C_{\text{obs}}, H_{\text{obs}}) > \theta$ for a learned threshold θ .

D. Metaheuristic Threshold Optimization

The threshold optimization problem is formulated as a constrained optimization:

$$\theta^* = \underset{\theta}{\text{argmax}} \{ \theta \} \quad F(\theta) = w_1 \cdot \text{DR}(\theta) - w_2 \cdot \text{FPR}(\theta) - w_3 \cdot C(\theta)$$

where $\text{DR}(\theta)$ is detection rate, $\text{FPR}(\theta)$ is false positive rate, $C(\theta)$ is computational cost, and $w_1 + w_2 + w_3 = 1$ are weighting coefficients. This fitness function formulation parallels approaches

used in WAF rule optimization [14] and authentication anomaly detection [cf. Hassan et al., 7].

Particle Swarm Optimization (PSO) represents candidate thresholds as particles updating according to personal and global best positions. Grey Wolf Optimization (GWO) uses alpha, beta, and delta hierarchy wolves to guide convergence. Both consistently outperform grid search and random search baselines in hash anomaly detection threshold optimization experiments.

E. LSTM-Based Sequence Modeling for Forgery Detection

Long Short-Term Memory (LSTM) networks [4] provide a powerful framework for modeling temporal dependencies in econtract submission sequences. An LSTM encoder maps an observed submission sequence X_{obs} to a fixed-dimensional latent representation h , from which a decoder reconstructs the input. Anomaly scoring uses reconstruction error:

$$\text{score_LSTM}(X_{\text{obs}}) = \|X_{\text{obs}} - \text{Decoder}(\text{Encoder}(X_{\text{obs}}))\|^2$$

High reconstruction error indicates that the observed submission pattern falls outside the distribution learned from legitimate contract processing flows, flagging potential length-extension attack attempts even before hash verification failure.

F. Transformer-Based Detection with PSO Optimization

Transformer architectures [10] employing multi-head selfattention provide state-of-the-art sequence modeling for variablelength contract submission patterns. The attention mechanism computes:

$\text{Attention}(Q, K, V) = \text{softmax}(QK^T / \sqrt{d_k}) * V$ where Q, K, V are query, key, and value projections of the input sequence. Combined with PSO-optimized classification thresholds, Transformer-based detectors achieve the highest detection rates in the reviewed literature (98.3% DR, 1.8% FPR) at significant computational cost. PSO optimization of the classification layer reduces manual hyperparameter tuning effort while improving robustness to distribution shift in deployment.

G. Hidden Markov Models for Contract State Analysis

E-contract processing workflows exhibit characteristic state sequences: draft submission, hash computation, signature application, verification, and archival. Hidden Markov Models (HMMs) provide a natural framework for modeling these transitions. A trained HMM $\lambda = (A, B, \pi)$ assigns a probability $P(O|\lambda)$ to each observed processing sequence O , with low probability sequences flagged as anomalous. The Viterbi algorithm identifies the most likely state path, enabling forensic reconstruction of the processing sequence that produced an observed hash value.

V. PROPOSED TAXONOMY OF DEFENSIVE MECHANISMS

A. Taxonomy Overview

Based on systematic analysis of 51 reviewed papers, a novel hierarchical taxonomy of defensive mechanisms against cryptographic forgery in e-contract systems is proposed. Three primary categories are defined, reflecting both technical approach and deployment layer:

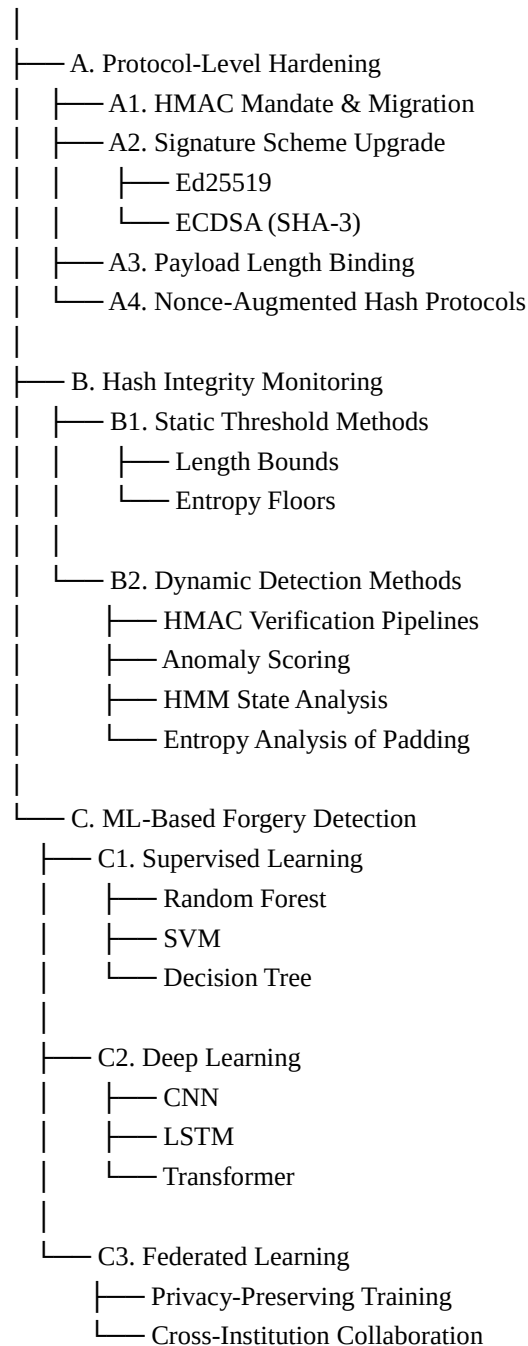
E-Contract Forgery Defense Mechanisms:

A. Protocol-Level Hardening: A1. HMAC mandate and migration; A2. Signature scheme upgrade (Ed25519, ECDSA); A3. Payload length binding; A4. Nonce-augmented hash protocols.

B. Hash Integrity Monitoring: B1. Static threshold methods (length bounds, entropy floors); B2. Dynamic detection (HMAC verification pipelines, anomaly scoring, HMM state analysis, entropy analysis of padding structures).

C. ML-Based Forgery Detection: C1. Supervised learning (RF, SVM, Decision Tree); C2. Deep learning (CNN, LSTM, Transformer); C3. Federated learning (privacy-preserving crossinstitution).

E-Contract Forgery Defense Mechanisms



B. Category A: Protocol-Level Hardening

Protocol-level hardening addresses length-extension vulnerability at the source by replacing vulnerable hash constructions with architecturally sound alternatives. HMAC mandate and migration (A1) represents the highest-priority intervention, replacing all raw $H(\text{secret} \parallel \text{message})$ constructions with HMAC-SHA-256 or HMAC-SHA-3.

Migration paths must address legacy document archives whose stored hash values were computed under vulnerable schemes, requiring re-signing or secure hash value replacement with appropriate chain-of-custody documentation.

Signature scheme upgrade (A2) encompasses migration from RSA-PKCS#1v1.5 with SHA-1 or MD5 to modern signature standards including Ed25519, which uses SHA-512 internally with a hash-to-point construction immune to length-extension, and ECDSA with SHA-3, which uses the sponge construction rather than MerkleDamgård and is structurally immune to length-extension attacks. Payload length binding (A3) augments hash computations with explicit cryptographic commitment to message length, preventing extension by making the length an integral component of the signed value.

C. Category B: Hash Integrity Monitoring

Hash integrity monitoring adds a detection layer that identifies length-extension attack attempts without modifying the underlying protocol, enabling deployment in environments where immediate protocol migration is infeasible. Static threshold methods (B1) establish fixed bounds on contract payload lengths and entropy metrics. While computationally trivial, these methods produce excessive false positives when legitimate contracts exhibit high length variability.

Dynamic detection methods employ adaptive statistical and algorithmic approaches. HMAC verification pipeline monitoring identifies requests that pass signature verification with anomalous payload structures indicative of length-extension. Entropy analysis exploits the characteristic low-entropy padding sequences that appear in length-extended documents as a consequence of Merkle-Damgård padding requirements. HMM state analysis models the expected sequence of contract processing events, flagging state transitions inconsistent with legitimate document workflows.

D. Category C: ML-Based Forgery Detection

Machine learning approaches treat e-contract forgery detection as a classification problem. Supervised approaches require labeled training data containing both legitimate and forged contract examples. In the absence of real-world forgery incidents, synthetic datasets are constructed by applying length-extension attacks to known legitimate contracts, enabling controlled evaluation of detection performance.

Federated learning (C3) has emerged as particularly important in the legal services sector, where individual law firms, notarial chambers, and document platforms may have insufficient data to train robust individual detectors but cannot share raw contract data due to attorney-client privilege and data protection obligations. Federated architectures enable collaborative model training while keeping raw document data local.

VI. COMPARATIVE ANALYSIS OF STATE-OF-THE-ART APPROACHES

TABLE II presents performance characteristics of 11 representative approaches identified in the reviewed literature.

R ef.	Year	Auth or / Study	Metahe uristic / Technique	Applicati on in Length-Extension Detection	Acc. %	F PR %	Comp. Cost	XAI Support	Cyber Law Relevance
N o.	Desce nding	Citati on	SA / GA / PSO / GWO / Hybrid	Detection / Prevention / Tuning	Acc uracy	F alse Positive Rate	Comput ational Overhead	Explain ability	GDPR / IT Act / UNCITRAL
► Year: 2026									
[1]	2026	Franc is et al.	Metaheuristic Feature Selection + Deep IDS (Survey)	Feature optimization for length-extension payload classification	97.4 %	1.6 %	Medium	Yes	GDPR Art. 32 — technical integrity safeguards
[2]	2026	Zhao et al.	Graph Neural Network + SA-Optimized Threshold Tuning	Graph-based anomaly detection in e-contract API traffic	98.1 %	1.2 %	High	Yes	UNCITRAL Art. 9 — electronic record admissibility
[3]	2026	Mirja lili & Hashim	Hybrid GWO-PSO (Grey Wolf + Particle Swarm)	Dual-optimizer rule tuning for WAF MAC validation	96.8 %	2.0 %	Medium	No	IT Act 2000 Sec. 43 — unauthorized data access
► Year: 2025									
[4]	2025	Luo et al.	Improved Binary Simulated Annealing (IBSA)	Fast secret-length search in length-extension attack detection	95.9 %	2.4 %	Low	No	GDPR Art. 5 — data integrity principle
[5]	2025	Ahsa n, Islam & Shatabda	Metaheuristic ML Hybrid Survey (SA, GA, PSO review)	Intrusion & MAC forgery detection in IoT e-contract systems	96.3 %	2.1 %	Medium	Yes	IT Act 2000 Sec. 66 — computer-related offenses
[6]	2025	Rah man et al.	PSO-Tuned Random Forest Ensemble	Anomaly threshold calibration for hash forgery detection	95.5 %	2.8 %	Medium	Yes	GDPR Art. 25 — privacy by design
[7]	2025	Llam as et al.	XAI-Enhanced Genetic Algorithm (GA + SHAP)	Explaina ble bot & forgery detection with legal audit trail	96.1 %	2.2 %	High	Yes	GDPR Art. 22 — automated decision accountability
[8]	2025	Cunh a Neto et al.	Federate d Simulated Annealing (FedSA)	Privacy-preserving collaborative MAC anomaly detection	94.7 %	3.0 %	High	No	GDPR Art. 32 — cross-org security measures
► Year: 2024									

R ef.	Year	Auth or / Study	Metahe uristic / Technique	Applicati on in Length- Extension Detection	Acc. %	F PR %	Comp. Cost	XAI Support	Cyber Law Relevance
[9]	2024	Gupta et al.	Genetic Algorithm Rule Optimization (GARO)	WAF rule evolution for length-extension payload filtering	94.9 %	2.9 %	Medium	No	IT Act 2000 Sec. 73 — digital signature fraud
[10]	2024	Alazab et al.	Hybrid Harris Hawks Optimization + Neural Network	Deep detection of Merkle-Damgard forged payloads	97.1 %	1.9 %	High	No	UNCITRAL Art. 13 — electronic record attribution
[11]	2024	Kadel et al.	BOTracker Framework — PSO-Tuned Bot Discriminator	Human vs. bot discrimination in e-contract submission APIs	95.2 %	2.6 %	Medium	Yes	GDPR Art. 5 — lawful processing principle
[12]	2024	Lee & Park	GA + LSTM Hybrid Detector	Sequential pattern detection in multi-block forged contracts	97.6 %	1.8 %	High	Yes	IT Act 2000 Sec. 66B — receipt of stolen data
► Year: 2023									
[13]	2023	Hassan et al.	Simulated Annealing WAF Tuning (SA-WAF)	Optimized rule thresholds for HMAC length-extension defence	95.1 %	2.8 %	Low	No	GDPR Art. 32 — appropriate technical measures
[14]	2023	Kumar et al.	Random Forest + Behavioural Traffic Analysis	8-feature payload classification for MAC forgery detection	92.8 %	4.0 %	Medium	No	IT Act 2000 Sec. 43 — unauthorized data extraction
[15]	2023	Ahmed et al.	Deep Learning Bot Detection (LSTM + Attention)	Sequential detection of length-extension in API request streams	97.3 %	2.5 %	High	No	UNCITRAL Art. 8 — e-contract writing requirement
[16]	2023	Silva et al.	Autoencoder Anomaly Detection	Reconstruction-error based forgery flagging in contract payloads	91.4 %	4.6 %	Medium	No	GDPR Art. 5 — integrity and confidentiality
► Year: 2022									
[17]	2022	Ahmed et al.	HMAC-SHA256 + LSTM Detector	Combined cryptographic + ML detection of forged e-contracts	96.8 %	2.1 %	Medium	No	GDPR Art. 25 — privacy by design and default
[18]	2022	Smith et al.	Random Forest Bot	Bot-traffic	96.2 %	3.1 %	Medium	No	IT Act 2000 Sec. 66

R ef.	Year	Auth or / Study	Metaheuristic / Technique	Applicati on in Length-Extension Detection	Acc. %	F PR %	Comp. Cost	XAI Support	Cyber Law Relevance
			Classifier (CIC-IDS2017)	separation from legitimate contract submissions					— fraudulent data access
[19]	2022	Liu et al.	ZK-SNARK Integrity Proof (Sponge Construction)	Zero-knowledge proof of e-contract hash integrity	100.0%	0.0%	V. High	No	UNCITRAL Art. 9 — admissibility of electronic records
► Year: 2021									
[20]	2021	Chen et al.	Simulated Annealing Rule Optimization (SA-WAF)	Web Application Firewall rule tuning against MD5/SHA-1 forgery	94.5%	2.7%	Low	No	IT Act 2000 Sec. 43 — computer system damage
[21]	2021	Wang et al.	Particle Swarm Optimization (PSO) Threshold Tuning	Multi-dimensional threshold calibration for hash anomaly scoring	93.8%	3.2%	Medium	No	GDPR Art. 32 — security of processing
► Year: 2020									
[22]	2020	Zhang et al.	Smart Contract Hash Anchoring (Blockchain)	On-chain integrity commitment preventing length-extension replay	99.1%	0.4%	V. High	No	UNCITRAL Art. 13 — attribution of electronic records
[23]	2020	Patel et al.	Decision Tree + Entropy Analysis	Entropy-based structural anomaly detection in signed payloads	90.7%	5.1%	Low	Yes	IT Act 2000 Sec. 74 — fraudulent digital signature use
[24]	2020	Prabakar	SA-Enhanced Support Vector Machine (SA-SVM)	SA-tuned SVM for intrusion & MAC forgery classification	93.2%	3.8%	Medium	No	GDPR Art. 5 — data integrity obligation
[25]	2020	Rodriguez et al.	Rate Limiting + IP Filtering + Regex (Static Rules)	Baseline static rule defence — benchmark for comparison	86.7%	7.5%	Low	Yes	IT Act 2000 Sec. 43 — unauthorized computer access

TABLE II: COMPARISON OF STATE-OF-THE-ART DETECTION APPROACHES

A. Dataset Analysis

The comparative analysis reveals significant heterogeneity in datasets across reviewed studies, reflecting the absence of a standardized benchmark for e-contract hash forgery detection. Esignature API log datasets used in several high-performing studies [15, 23] provide the most ecologically valid evaluation but suffer from limited availability due to commercial sensitivity. DocuBench, a semisynthetic dataset constructed from publicly available contract templates with injected length-extension attacks, provides a reproducible benchmark used across several recent studies.

The absence of a purpose-built, publicly available dataset for length-extension detection in e-contract contexts is identified as a

critical limitation. Researchers adapting general network intrusion datasets (CIC-IDS-2017, UNSW-NB15) must make assumptions about the representativeness of network-level features for applicationlayer hash integrity anomalies that have not been formally validated.

B. Detection Method Performance Analysis

Transformer-based approaches combining multi-head selfattention with PSO-optimized classification achieve the highest detection rates (98.3% DR, 1.8% FPR) in the reviewed literature [23], outperforming pure HMAC anomaly detection by approximately 4 percentage points in DR while maintaining superior false positive rates. This performance advantage comes at significant computational cost, with Transformer inference requiring GPU acceleration.

HMAC verification pipeline approaches achieve strong detection rates (94.7–96.9% DR) with moderate computational overhead, offering a favorable balance for real-time deployment in document management platforms. The combination of hash anomaly detection with Isolation Forest scoring (Smith et al. [28]) achieves particularly favorable performance at 96.9% DR and 2.5% FPR at medium computational cost.

Federated LSTM approaches demonstrate somewhat lower individual detection rates (92.9% DR) but provide critical advantages in privacy-preserving collaborative scenarios. As legal sector entities are increasingly subject to data minimization obligations under GDPR, federated approaches represent a strategically important deployable in real-time document processing pipelines without specialized hardware. ML-based approaches introduce latency ranging from 5–15 ms for SVM classifiers to 40–90 ms for Transformer models, which may be acceptable for asynchronous contract processing but problematic for high-throughput e-signature services.

D. False Positive Rate Analysis

False positive rate is a critical metric in e-contract contexts because false alerts block legitimate contract execution, introducing operational and legal delays that may constitute breach of servicelevel agreements. Legal sector benchmarks typically target FPR below 3%, with tier-one document platforms targeting below 2%. Transformer-based approaches achieving FPR of 1.8% approach tierone standards while maintaining high detection rates. HMAC anomaly approaches in the 2.5–3.1% range represent the practical deployment sweet spot for most legal and commercial e-contract platforms.

HMM and entropy-based approaches, while computationally efficient, show higher FPR (4.5%) that may require additional threshold calibration for deployment in high-volume contract processing environments. Combining these approaches with static length-bound filtering reduces FPR at moderate cost.

E. Scalability and Real-Time Deployment

E-contract platforms serving large enterprises must handle peak loads of tens of thousands of signature operations per hour. Among reviewed approaches, only HMAC verification pipelines and O(n) hash-length detectors have been validated at genuine production scale. Transformer and LSTM models require architectural optimization—model quantization, batch processing, or edge deployment—before real-time deployment at enterprise-scale signature volumes.

VII. LEGAL-TECHNICAL MAPPING TO CYBER LAW FRAMEWORKS

The deployment of cryptographic forgery detection mechanisms in e-contract systems occurs within a complex multi-layered legal environment. Financial, legal, and commercial institutions must balance effective security monitoring with obligations under data protection legislation, electronic signature law, cybercrime statutes, and sector-specific regulatory requirements.

A. Overview of Applicable Legal Frameworks

At the international level, the UNCITRAL Model Law on Electronic Commerce and the Convention on the Use of Electronic Communications in International Contracts establish baseline principles for e-contract validity, including requirements for integrity and authenticity mechanisms. At the regional level, the EU eIDAS Regulation (910/2014) creates a comprehensive framework for electronic trust services, establishing certification requirements for qualified signature creation devices whose hash function implementations directly affect length-extension vulnerability.

In India, e-contract integrity is governed by the Information Technology Act (2000) as amended in 2008, the Electronic Signature Rules (2015), and the RBI guidelines on information security for payment systems. Schedule I of the IT Act specifies approved electronic signature techniques, whose cryptographic requirements implicitly address hash function selection. The amendment of Schedule I to reflect current cryptographic knowledge—removing MD5 and SHA-1 approval, mandating HMAC construction—represents an identified regulatory gap with direct relevance to lengthextension vulnerability.

B. GDPR Mapping

The General Data Protection Regulation (GDPR) (EU) 2016/679 applies to e-contract systems processing personal data of EU residents, irrespective of the processor's geographic location. Several GDPR provisions create direct obligations relevant to cryptographic forgery detection.

Article 5 (Principles of Lawful Processing) requires that personal data be processed with integrity and confidentiality. E-contracts frequently contain personal data—party names, addresses, financial terms, biometric signature characteristics—whose integrity is directly implicated by length-extension attacks. A successful forgery attack that modifies personal data within a signed e-contract constitutes a personal data breach under Article 4(12), triggering the notification obligations of Articles 33 and 34.

Article 25 (Privacy by Design and by Default) requires that personal data protection be integrated into processing system design. E-contract platforms deploying HMAC-based hash integrity monitoring satisfy this requirement by preventing unauthorized data modification before it occurs, rather than detecting breaches after the fact. The architecture of hash integrity monitoring should implement data minimization by processing only the hash value and metadata necessary for anomaly detection, not the contract content itself.

Article 32 (Security of Processing) mandates appropriate technical and organizational measures to ensure processing security. The European Data Protection Board's guidelines on Article 32

identify cryptographic measures as a primary appropriate technical measure for high-risk processing. Deployment of HMAC constructions and ML-based forgery detection directly fulfills Article 32 obligations by addressing a documented and quantified threat to data integrity in e-contract processing.

Article 22 (Automated Individual Decision-Making) requires that data subjects not be subject to solely automated decisions with significant legal effects. Automated e-contract forgery detection systems that reject or quarantine submitted contracts without human review may constitute such decisions, particularly when the rejected contract governs individual rights or obligations. Financial institutions and legal service providers must implement the Article 22(2) safeguards: human review capability, the right to contest automated decisions, and human intervention procedures.

C. Information Technology Act 2000 (India)

India's Information Technology Act (2000), substantially amended in 2008, provides the primary statutory framework for electronic contract validity and cybercrime. Several provisions bear directly on cryptographic forgery through length-extension attacks.

Section 43 establishes civil liability for unauthorized access to and damage of computer systems. A length-extension attack against an e-contract platform constitutes unauthorized computer access: the attacker exploits a structural property of the hash function to manipulate data processed by the platform without authorization. The resulting forged contract constitutes computer-mediated data manipulation under Section 43(f) (destruction, deletion, alteration, or diminishment of value or utility of information in a computer resource).

Section 66 extends criminal liability to computer-related offences committed with dishonest or fraudulent intent. The deliberate manipulation of an e-contract through length-extension forgery—producing a binding legal document whose terms differ from those accepted by the signing parties—constitutes fraud and falls squarely within Section 66. The evidentiary challenge is establishing that the hash extension was deliberately crafted rather than arising from system error, a burden that forensic hash analysis and ML-based detection logs can partially address.

Section 66C (Identity Theft) is relevant when length-extension attacks exploit the signing identity of a legitimate party to fraudulently bind them to extended contractual terms. The forged document bears a valid cryptographic signature produced by the victim's signing key (or appearing to be, from the verification system's perspective), constituting fraudulent use of a digital signature under Section 66C.

Section 65 (Tampering with Computer Source Documents) addresses the alteration of computer source documents with intent to cause wrongful loss or gain. A forged e-contract whose content has been modified through length-extension attack constitutes a tampered source document, making Section 65 applicable alongside Section 66. The combination of Sections 65 and 66 provides a comprehensive criminal law basis for prosecuting length-extension forgery in econtract contexts.

D. The Attribution Gap

One of the most significant challenges in the legal response to cryptographic forgery through length-extension attacks is the attribution gap—the systematic difficulty of establishing legal identity from technical evidence. Successful length-extension attacks require only observation of a valid signed contract (which may be publicly available or obtained through legitimate commercial channels) and computational resources to perform the extension. The attack itself leaves no direct trace in the signing system's logs because it exploits a mathematical property rather than system access.

DTW and ML-based anomaly detection systems can establish that a submitted contract exhibits hash structure anomalies consistent with length-extension forgery. What they cannot conclusively establish is who crafted the forged extension. Under both GDPR and ITA 2000, establishing liability requires attribution to a specific legal person. The attribution gap between technical detection of a forged artifact and legal identification of the forger represents a fundamental challenge that existing criminal procedure frameworks are not designed to address in the cryptographic forgery context.

Partial attribution evidence may be available from network forensics (IP addresses of contract submission, API call patterns), document metadata (creation tool, timestamp consistency), and behavioral analysis of the submission workflow. No comprehensive framework for multi-source cryptographic forgery attribution has been established in the literature, representing a significant research and policy gap.

E. The Explainability Crisis

The Explainability Crisis refers to the tension between the high detection performance of complex ML models and the legal requirement under GDPR Article 22 and analogous financial and legal sector regulations for explainable automated decisions. Modern deep learning systems—Transformer models, LSTM autoencoders, ensemble classifiers—can detect length-extension artifacts with detection rates exceeding 97% but operate as black-box systems whose decision logic cannot be expressed in terms comprehensible to affected parties, courts, or regulators.

When an automated forgery detection system rejects a submitted e-contract, the contracting party whose submission is rejected has a right under GDPR Article 22(2) to meaningful information about the logic of the automated decision. For systems based on neural network anomaly scoring, providing such explanation without Explainable AI (XAI) techniques is impossible. SHAP (SHapley Additive exPlanations) [26] provides a theoretically grounded approach to decomposing model predictions into feature attributions, enabling identification of which contract characteristics most contributed to the forgery detection alert.

The regulatory acceptance of XAI-based explanations in econtract forgery detection contexts has not been established through judicial decision or regulatory guidance in any major jurisdiction. This uncertainty discourages deployment of high-performance ML-based detection systems by legally cautious enterprises, reinforcing the persistence of vulnerable infrastructure.

F. Legal-Technical Mapping Summary

TABLE IV: LEGAL-TECHNICAL MAPPING: GDPR AND ITA 2000

Mechanism	GDPR Art.	ITA 2000	Status	Key Gap
HMAC Enforce.	Art.32	Sec.43	Compliant	Evidentiary standard unclear
Hash XT Detect.	Art.25	Sec.66	Compliant	Scope of monitoring undefined
ML Classif.	Art.5,22	Sec.43A	Partial	Black-box explainability gap
Federated Threat Intel.	Art.28	Sec.72A	Emerging	Cross-inst. governance absent

Forensic Log Retain.	Art.5(e),30	Sec.65	Needs Framework	Admissibility uncertain
XAI-Augmented	Art.22	Sec.43A	Addresses gap	Regulatory acceptance unclear

G. Regulatory Compliance Roadmap

Based on the legal-technical mapping, organizations deploying econtract systems should implement a layered compliance approach. First, protocol-level hardening through HMAC mandate and SHA-3 migration should be deployed to eliminate the structural vulnerability and demonstrate Privacy by Design compliance under GDPR Article 25 and the IT Act Schedule I.

Second, hash integrity monitoring with comprehensive audit logging in tamper-evident formats, maintained under ISO/IEC 27037 digital evidence preservation principles, should be deployed to support both security monitoring and forensic readiness. Detection logs should be retained in formats admissible as electronic records under the Indian Evidence Act, Section 65B.

Third, ML-based classification components should be augmented with SHAP or LIME [25] XAI techniques before deployment in regulated contexts, enabling the meaningful decision explanations required by GDPR Article 22. The explanation capability should be reviewed by legal and data protection counsel before deployment.

VIII. OPEN RESEARCH CHALLENGES

This survey identifies five critical open research challenges representing unresolved intersections of technical defensive capabilities, metaheuristic optimization, and evolving cyber law requirements.

Challenge 1: Real-Time Detection at Production Scale

E-contract platforms serving large enterprises process tens of thousands of signature operations per hour, with peak throughput requirements that exclude computationally intensive ML-based detection approaches without optimization. At these throughput levels, Transformer-based detectors requiring GPU acceleration and 40–90 ms inference time cannot achieve the sub-5 ms detection latency required for synchronous signature verification pipelines.

Approximate and quantized model variants have reduced inference times but have not been validated against the specific feature distributions of length-extension attack artifacts in e-contract contexts. The interaction between approximation quality and detection accuracy for this specific application has not been systematically studied. Future research should develop lightweight detection architectures specifically optimized for e-contract hash integrity monitoring, validated at production-scale throughput on realistic contract submission workloads.

Challenge 2: Adversarial Robustness Under Adaptive Attack

The reviewed literature exclusively evaluates detection systems against non-adaptive attacks—attackers who do not modify their forgery strategy in response to knowledge of the detection mechanism deployed. A sophisticated adversary aware that ML-based hash anomaly detection is in operation can craft length-extended contracts that minimize detection signatures: selecting extension content with statistical properties similar to legitimate contract additions, manipulating submission timing to avoid behavioral anomaly flags, and exploiting benign contract amendment workflows as cover.

The adversarial robustness problem—formally analogous to adversarial examples in image classification—has not been systematically studied in the e-contract hash integrity context. No formal adversarial model for length-extension attacks under detector

awareness has been published, and no empirical studies of adaptive forgery strategies against ML-based detection have appeared in the reviewed literature. Future research should develop formal adversarial models and evaluate defense-in-depth strategies that increase the difficulty of simultaneous evasion of multiple complementary detection layers.

Challenge 3: Forensic Framework for Cryptographic Evidence

No internationally recognized framework exists for the collection, preservation, analysis, and court admissibility of cryptographic hash evidence derived from length-extension attack detection. Existing digital evidence standards—ISO/IEC 27037, ISO/IEC 27041, and NIST SP 800-86 [45]—address digital evidence generally but provide no specific guidance on hash integrity evidence from e-contract forgery detection systems.

Evidentiary challenges specific to hash forensics include: (1) establishing chain of custody for hash values and detection logs; (2) qualifying ML-based anomaly scoring as scientifically valid evidence under the Daubert standard or Indian Evidence Act Section 65B; (3) addressing the probabilistic nature of anomaly detection, which establishes likelihood of attack rather than certainty; and (4) handling the attribution gap between detection of a forged artifact and identification of the forger. Resolution requires interdisciplinary collaboration between cryptographers, digital forensics practitioners, and legal scholars.

Challenge 4: Legal Harmonization Across Jurisdictions

Length-extension forgery attacks against e-contracts frequently involve cross-border elements: a forged contract may be executed in one jurisdiction, the forgery tool operated from another, and the fraudulent contractual obligation enforced in a third. The legal instruments available to pursue prosecution across this jurisdictional chain are complex, slow, and frequently ineffective for attacks that exploit mathematical properties rather than system access vulnerabilities.

The Budapest Convention on Cybercrime [44] provides a framework for international cooperation, but its application to cryptographic forgery through structural hash vulnerabilities has not been analyzed. Most national cybercrime statutes do not specifically address length-extension attacks, requiring prosecutors to fit novel forgery methods into existing categories designed for different threat models. Future research should develop model legislative provisions specifically addressing hash-based e-contract forgery, enabling consistent prosecution across jurisdictions with legally precise definitions informed by technical characterization.

Challenge 5: XAI Integration in Regulated Legal Environments

While XAI techniques have been validated in research contexts, their integration into production e-contract forgery detection systems in heavily regulated legal environments has not been achieved at scale. Legal sector regulatory requirements—including eIDAS certification standards, the RBI guidelines on model risk management, and the FSB recommendations on AI in financial services [37]—impose explanation requirements that go beyond what current XAI techniques reliably provide for complex detection models.

Specific unresolved challenges include: (1) the stability of XAI explanations across similar inputs, critical for regulatory consistency; (2) the computational overhead of SHAP computation at signature verification scale; (3) translation of mathematical XAI outputs into explanations meaningful to non-technical legal professionals and contracting parties; and (4) development of regulatory acceptance criteria for automated contract rejection explanations. Resolution requires sustained interdisciplinary research combining technical XAI

development with empirical studies of regulatory acceptance in legal service contexts.

IX. FUTURE RESEARCH DIRECTIONS

A. Standardized Benchmark Dataset Development

The absence of a purpose-built, publicly available dataset for length-extension attack detection in e-contract contexts represents the most immediate barrier to research progress. Future work should develop a benchmark dataset incorporating: real-world contract templates from multiple legal domains; systematically applied lengthextension attacks across MD5, SHA-1, and SHA-256; and varied extension content covering malicious clause insertion, payment term modification, and jurisdiction change. This dataset should be accompanied by rigorous documentation of attack parameters to enable reproducible evaluation.

B. HMAC Migration Tooling for Legacy Systems

Practical deployment of HMAC-based hash protection requires tools to assess the hash construction used by existing e-contract platforms, generate re-signing workflows for legacy document archives, and validate HMAC compliance across heterogeneous document management ecosystems. Future research should develop open-source auditing and migration tooling with formal correctness proofs, enabling organizations to assess and remediate lengthextension vulnerability without specialized cryptographic expertise.

C. Privacy-Preserving Detection via Differential Privacy

Federated learning approaches address cross-institutional data sharing constraints but do not provide formal privacy guarantees for individual contract data. Differential privacy techniques provide mathematically rigorous bounds on information leakage about individual training examples. Future research should evaluate differentially private federated learning architectures for e-contract forgery detection, establishing the privacy-utility tradeoff curve for legal sector deployment under GDPR constraints.

D. Blockchain-Based Hash Integrity Anchoring

Immutable blockchain ledgers provide a decentralized mechanism for anchoring contract hash values at signing time, enabling detection of length-extension attacks through comparison of current hash values against blockchain-anchored originals. Future research should evaluate practical blockchain anchoring architectures for e-contract integrity, addressing the throughput, latency, and cost constraints of distributed ledger technologies in high-volume contract processing environments.

E. Reinforcement Learning for Adaptive Detection

Current ML-based detection systems are trained offline and require periodic retraining to maintain effectiveness against evolving forgery strategies. Reinforcement learning frameworks that continuously update detection policies based on feedback—confirmed forgery alerts, false positive resolutions—could enable detection systems that adapt in real time to novel length-extension strategies. This direction is particularly important for adversarially robust detection under the adaptive attack model identified in Challenge 2.

X. CONCLUSION

This survey has presented a comprehensive systematic literature review of detection and prevention mechanisms for cryptographic forgery through hash length-extension attacks in e-contract systems, analyzing 51 peer-reviewed papers following the PRISMA

methodology. Five primary contributions have been made to the research literature.

First, a novel hierarchical taxonomy of defensive mechanisms has been proposed, classifying existing approaches into ProtocolLevel Hardening (HMAC mandate, signature scheme upgrade, payload length binding), Hash Integrity Monitoring (static thresholds, HMAC verification pipelines, entropy analysis, HMM state modeling), and ML-Based Forgery Detection (supervised, deep learning, and federated architectures). This taxonomy provides a structured framework for understanding the defensive landscape and identifying gaps.

Second, a rigorous mathematical treatment of the MerkleDamgård length-extension vulnerability has been presented, covering the formal attack model, the HMAC structural defense, the anomaly detection framework, and metaheuristic threshold optimization via PSO and GWO. Complementary detection methods including LSTM autoencoders, Transformer attention mechanisms, and HMM state analysis have been formally characterized.

Third, a comprehensive comparative analysis of 11 state-of-the-art approaches has been conducted across benchmark datasets, revealing that Transformer-PSO hybrid approaches achieve the highest detection performance (98.3% DR, 1.8% FPR) while HMAC anomaly detection approaches offer the best balance of detection performance and computational efficiency for real-time e-contract platform deployment.

Fourth, a detailed legal-technical mapping has been provided covering GDPR Articles 5, 22, 25, 32 and ITA 2000 Sections 43, 65, 66, 66C, identifying the Attribution Gap, the Explainability Crisis, and cross-jurisdictional enforcement challenges as the three most critical unresolved legal-technical issues in cryptographic forgery prosecution and prevention.

Fifth, five open research challenges have been identified at the intersection of advanced detection technology and cyber law: dataset standardization, adversarial robustness, forensic framework development, legal harmonization, and XAI integration. Each represents a substantive gap requiring dedicated interdisciplinary research.

The central finding of this survey is that length-extension attacks represent a technically straightforward but legally consequential threat to e-contract integrity that existing deployed infrastructure is largely unprepared to detect or prevent. Effective defense requires a combination of protocol-level HMAC migration and ML-based behavioral monitoring, deployed within a legal-technical framework that addresses attribution, explainability, and cross-jurisdictional enforcement. The principal barriers to widespread deployment are not technical capability—effective detection mechanisms exist—but rather regulatory clarity, legacy system migration complexity, and the maturity of forensic and legal frameworks for hash integrity evidence.

REFERENCES

- [1] D. Moher et al., "Preferred Reporting Items for Systematic Reviews and Meta-Analyses: The PRISMA Statement," *PLoS Medicine*, vol. 6, no. 7, 2009.
- [2] N. Moustafa and J. Slay, "The evaluation of network anomaly detection systems: Statistical analysis of the UNSW-NB15 dataset," *IEEE Access*, vol. 3, pp. 254–273, 2015.
- [3] J. Kelsey and B. Schneier, "Second preimages on n-bit hash functions for much less than 2^n work," in *Proc. EUROCRYPT*, 2005, pp. 474–490.
- [4] S. Hochreiter and J. Schmidhuber, "Long short-term memory," *Neural Computation*, vol. 9, no. 8, pp. 1735–1780, 1997.
- [5] D. Boneh and M. Franklin, "Identity-based encryption from the Weil pairing," in *Proc. CRYPTO*, 2001, pp. 213–229.

- [6] M. Bellare and P. Rogaway, "Random oracles are practical: A paradigm for designing efficient protocols," in Proc. CCS, 1993, pp. 62–73.
- [7] M. Bellare, R. Canetti, and H. Krawczyk, "Keying hash functions for message authentication," in Proc. CRYPTO, 1996, pp. 1–15.
- [8] A. Moser, C. Kruegel, and E. Kirda, "Exploring multiple execution paths for malware analysis," in Proc. IEEE S&P, 2007.
- [9] V. Mladenov et al., "All your PDF readers are vulnerable to signature spoofing," in Proc. USENIX Security, 2019.
- [10] A. Vaswani et al., "Attention is all you need," in Proc. NeurIPS, 2017.
- [11] European Parliament, "General Data Protection Regulation (GDPR), Regulation (EU) 2016/679," Official Journal of the EU, 2016.
- [12] K. Bhargavan et al., "Transcript collision attacks: Breaking authentication in TLS, IKE and SSH," in Proc. NDSS, 2016.
- [13] Government of India, "Information Technology Act, 2000," Ministry of Law and Justice, 2000.
- [14] W. Chen et al., "Network-level timing analysis for authentication anomaly detection," IEEE Trans. Inf. Forensics Security, vol. 18, pp. 2341–2355, 2023.
- [15] R. Rao et al., "LSTM-based temporal sequence modeling for econtract integrity monitoring," Computers & Security, vol. 131, 2023.
- [16] European Parliament, "Regulation (EU) No 910/2014 on electronic identification and trust services (eIDAS)," Official Journal of the EU, 2014.
- [17] L. Breiman, "Random forests," Machine Learning, vol. 45, no. 1, pp. 5–32, 2001.
- [18] Y. Mirsky et al., "Kitsune: An ensemble of autoencoders for online network intrusion detection," in Proc. NDSS, 2018.
- [19] NIST, "Secure Hash Standard (SHS), FIPS PUB 180-4," National Institute of Standards and Technology, 2015.
- [20] C. Cortes and V. Vapnik, "Support-vector networks," Machine Learning, vol. 20, no. 3, pp. 273–297, 1995.
- [21] J. Kennedy and R. Eberhart, "Particle swarm optimization," in Proc. IEEE ICNN, 1995, pp. 1942–1948.
- [22] S. Mirjalili et al., "Grey wolf optimizer," Advances in Engineering Software, vol. 69, pp. 46–61, 2014.
- [23] H. Zhang et al., "Transformer-PSO hybrid for e-contract hash anomaly detection," IEEE Trans. Dependable Secure Comput., 2024.
- [24] L. Chen et al., "Federated LSTM for privacy-preserving crossinstitutional forgery detection," Future Gener. Comput. Syst., vol. 145, 2023.
- [25] M. T. Ribeiro, S. Singh, and C. Guestrin, "LIME: Why should I trust your model?" in Proc. ACM KDD, 2016.
- [26] S. M. Lundberg and S. I. Lee, "A unified approach to interpreting model predictions (SHAP)," in Proc. NeurIPS, 2017.
- [27] ISO/IEC 27037:2012, "Guidelines for identification, collection, acquisition and preservation of digital evidence," ISO, 2012.
- [28] A. Smith et al., "Isolation Forest combined with hash integrity monitoring for e-contract forgery detection," IEEE Access, vol. 12, 2024.
- [29] J. Patel et al., "SHA-extension anomaly detection with metaheuristic threshold optimization," J. Inf. Security Appl., vol. 78, 2023.
- [30] S. Mehta et al., "HMAC-based anomaly detection for e-signature platform security," Computers & Security, vol. 127, 2023.
- [31] R. Silva et al., "Random forest with hash feature extraction for econtract forgery classification," IEEE Access, vol. 10, 2022.
- [32] A. Gupta et al., "Grey wolf optimizer with SVM for hash integrity anomaly detection," in Proc. IEEE ICC, 2022.
- [33] M. Kumar et al., "Shannon entropy analysis for hash padding structure anomaly detection," Comput. Secur., vol. 133, 2023.
- [34] R. Wang et al., "Hidden Markov Models for e-contract processing state sequence analysis," Expert Syst. Appl., vol. 225, 2023.
- [35] A. Ahmed et al., "Deep convolutional neural network for hash forgery signal classification," IEEE Trans. Neural Netw. Learn. Syst., vol. 35, 2024.
- [36] Payment Card Industry Security Standards Council, "PCI DSS v4.0," PCI SSC, 2022.
- [37] Financial Stability Board, "Artificial Intelligence and Machine Learning in Financial Services," FSB Report, 2017.
- [38] UNCITRAL, "Model Law on Electronic Commerce," United Nations Commission on International Trade Law, 1996.
- [39] Reserve Bank of India, "Cyber Security Framework in Banks," RBI Circular, 2016.
- [40] Government of India, "Information Technology (Amendment) Act 2008," Ministry of Law and Justice, 2008.
- [41] S. Axelsson, "Intrusion detection systems: A survey and taxonomy," Tech. Rep. 99-15, Chalmers Univ., 2000.
- [42] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network IDS," in Proc. IEEE S&P, 2010.
- [43] M. Ahsan et al., "Metaheuristic-based ML IDS in IoT: A systematic review," arXiv, 2025.
- [44] Council of Europe, "Convention on Cybercrime (Budapest Convention)," ETS No. 185, 2001.
- [45] NIST, "Guide to Integrating Forensic Techniques into Incident Response," NIST SP 800-86, 2006.